CloudDesk Technologies

Change Management Policy

1. Authority, scope and responsibilities

SYNTHETIC / DEMO - document control

CD-CHG-001 | Version 1.0 (wording revision). Proposed effective date: 2026-10-22. Planned next review: 2027-10-22. These dates are proposals, not an approved schedule. Owner and process coordinator: Engineering Lead. Accountable risk approver: CTO; approval not recorded. Review annually and after material changes, significant incidents or failed changes.

Status and adoption limits

CloudDesk Technologies is a fictional 75-person B2B SaaS vendor. This model-authored policy sets proposed SYNTHETIC / DEMO requirements, not operating facts. Review_status: requires_user_review. No implemented controls, completed deployments, existing staff coverage or approvals are asserted. It makes no claim about an SLA, deployment frequency, certification, SOC 2 report or compliance. Human review and recorded approval are required before adoption.

Scoped changes and related authority

This policy covers changes that affect production, including development work with a production impact. It covers application code, database schemas and data migrations. It also covers infrastructure and infrastructure as code (IaC), cloud configuration and security controls. Identity permissions, encryption keys, backup methods, recovery runbooks and vendor integrations are in scope. Include manual console changes, feature flags, scripts and vendor-driven changes that affect production. The five related policies remain authoritative for access, encryption, risk, incident authority and backup/disaster recovery. Record conflicts and have the Engineering Lead and CTO resolve them before adoption.

Responsibilities and independent review

System owners and change requesters must document impact, dependencies, tests, deployment, monitoring and rollback. The Engineering Lead coordinates classification, scheduling, approvals and records. The CTO accepts material residual risk and authorizes exceptions. Assign a competent independent reviewer where feasible. Separate requester, reviewer and deployment approval duties. No staffed change board or dedicated release team is assumed. If limited capacity prevents separation, record the conflict. Obtain CTO approval of compensating review before a planned deployment; do not silently self-approve.

Change Management Policy

2. Classification, requests and authorization

Standard changes - bounded preauthorization

A standard change is repeatable and low risk only within a documented, tested procedure preauthorized by the Engineering Lead. The CTO must accept any material residual risk. A proposed standard-change catalogue must define eligibility, exact scope, version, validation, rollback, authorized operators and review/expiry conditions. Each execution still needs a ticket, eligibility check and recorded preauthorization before deployment. No catalogue is supplied or approved here. A deviation, failed validation or changed risk removes eligibility and requires normal or emergency handling.

Normal changes and approval gates

A normal change is a planned change in scope that lacks valid standard preauthorization. Before deployment require peer review, system-owner acceptance of service impact and Engineering Lead process approval. The CTO approves material residual risk, major service impact and exceptions. Record named decision makers, decision time, scope and conditions. Reassess and reapprove if scope, artifact, risk or timing materially changes. A merged pull request is not by itself proof of deployment authorization or a successful release.

Ticketed change request

Give each change a unique ID. Record the requester, owner, classification rationale, affected services/assets, tenant scope and dependency map. Record exact artifact/configuration versions and linked pull requests. Assess business impact, security, privacy, cross-tenant risks, data migration reversibility, availability and vendor obligations.

Include test evidence and limitations, deployment steps, proposed timing and time zone, and communications. Include verification/stop criteria, a rollback or forward-recovery plan, decision authority and linked risks/incidents. Keep secrets and unnecessary customer data out of tickets.

Emergency classification and risk assessment

Use emergency changes for active harm or urgent exposure when the normal process would increase risk. Convenience or missed planning is insufficient. Link an incident. Record urgency, alternatives, expected harm, minimum safe testing and recovery dependencies. Assess risks before material service changes and vendor onboarding under CD-ISP-001. Keep its requirements for risk assessment at least annually and quarterly open-risk reviews. The CTO accepts material residual risk. Page 5 sets emergency authority and retrospective review; do not wait for routine approvals to stop active harm.

Change Management Policy

3. Engineering safeguards and testing

Version control, peer review and CI

Keep production code, infrastructure definitions and reviewable configuration in version-controlled pull requests. Link each change ticket to its pull request. Record the exact reviewed commit and immutable release artifact identifier or digest. Require peer review of security and privacy impact. Review CI/tests appropriate to the change. Include unit, integration and migration checks. Keep test evidence and record failures and how they were resolved. Block planned release on unresolved required checks unless an approved, bounded exception applies. Protect production branches and deployment permissions as proposed safeguards. This policy claims no existing repository protection or pipeline.

Secrets, access and encryption safety

Review diffs and CI output for secrets. Use the approved secrets manager, restricted service identities and redacted logs. Do not copy credentials, private keys or production data into repositories or build artifacts. Preserve unique user accounts and multi-factor authentication for administrative access. Keep access reviews every quarter and termination revocation within 24 hours. Changes in scope must preserve AES-256 at rest and TLS 1.2 or TLS 1.3 in transit. Keep managed non-exportable KMS keys. Key administrators have no default decrypt permission. The Engineering Lead approves key grants; review grants quarterly.

Tenant isolation and migration tests

Test authorized tenant workflows and negative cross-tenant access attempts. Where affected, cover object identifiers, API authorization, exports, background jobs, caches and privilege changes. Use synthetic data or authorized, minimized test data in isolated environments. Test schema compatibility, old/new application coexistence, duplicate event handling and rollback of partially applied migrations. Failed tenant isolation, authorization or integrity checks block planned release. Preserve results and remediate. A passing test suite does not prove that every tenant path is secure.

Restore, key dependencies and disaster recovery

For changes affecting storage, keys, identity, backups or recovery, test a representative encrypted restore and authorized key access as appropriate before planned rollout. Document integrity, recovery outcome and dependency limitations. Preserve backup-specific key grants and required older key versions for retained data/backups and holds. Rotate symmetric key-encryption keys at least every 12 months. Rotation alone does not re-encrypt historical data. Destruction requires Engineering Lead and CTO approval after retention and recovery checks. Change testing supplements representative encrypted restore tests at least quarterly. It also supplements continuity exercises at least annually and after material changes; neither substitutes for the other.

Change Management Policy

4. Scheduling, deployment and verification

Timing, coordination and change freeze

The Engineering Lead coordinates a proposed change calendar, dependent releases, vendor windows, customer impact and available authorized support. Choose timing based on risk and contractual commitments. No fixed deployment cadence, maintenance window or staffed coverage is assumed. Record a change freeze for sensitive business periods, unstable service or incidents. State its scope, owner and end conditions. Defer planned changes in scope during a freeze. The CTO approves documented risk-based exceptions. Urgent containment follows incident authority even during a freeze.

Staged rollout and controlled execution

Before deployment, verify approvals or valid standard preauthorization, reviewed artifact identity and required tests. Also verify recovery readiness, trusted access and the communication plan. Deploy through authorized identities using a recorded runbook. Where feasible, use staging, canary cohorts or feature flags. Expand only after defined health and tenant checks. Record manual console actions and reconcile them into reviewed configuration/IaC. Pause when monitoring or responsible authorized coverage is unavailable; assess an emergency separately. Staging success does not prove production safety.

Post-deployment verification and monitoring

Compare actual production state with the approved version. Check application health, error rates, latency, security signals, tenant boundaries, data integrity and affected user workflows against ticketed acceptance criteria. Set an observation period and escalation contacts based on each change's risk; this policy sets no universal time limit. Record who verified, when, observed results, gaps and the decision to expand, hold or stop. The system owner records acceptance. The Engineering Lead checks closure evidence. The CTO approves material residual risk and critical-service return under incident authority when applicable.

Failed changes, rollback and forward recovery

Stop rollout on failed acceptance criteria, suspected tenant exposure, integrity loss or returning incident indicators. Use the validated rollback plan only if safe. For irreversible migrations, review a forward-recovery or restore plan and decision authority before planned deployment. Preserve evidence, record actual state and isolate unsafe paths. Do not blindly restore an old version. Link or open an incident for suspected exposure or material disruption. The Engineering Lead coordinates recovery, verifies containment and escalates material risk to the CTO. Retest before redeployment.

Change Management Policy

5. Emergency changes and policy boundaries

Immediate containment authority

Under CD-IRP-001, responders may take urgent reversible action to stop active harm. Document the scope and inform the Engineering Lead and CTO. Do not delay immediate containment solely for a ticket, routine approval or evidence collection. Create or complete the linked incident/change record as soon as safe. The CTO authorizes material service shutdowns and residual-risk decisions. Seek verified alternate approval if the CTO is unavailable, and record unavoidable emergency decisions for review. This process does not expand authority for destructive actions, emergency decrypt access or external communications.

Emergency safeguards and next business day review

Use the smallest safe change, trusted identities and rapid peer input where feasible. Use minimum relevant testing, monitoring and a rollback/recovery path. Record omitted checks and why they were omitted. Record actions, artifact versions, actor, time, affected tenants, authorization basis and known uncertainty. The Engineering Lead coordinates retrospective documentation. The CTO reviews emergency changes by the next business day. Review necessity, scope, decisions, results and remaining risk. Assign corrective actions and reconcile hotfixes into version control. Retrospective review does not turn an unauthorized action into prior approval.

Key, backup and recovery constraints

For suspected key compromise, open an incident, revoke affected grants and disable compromised versions where safe. Never blindly destroy keys needed for recovery. The CTO authorizes temporary emergency decrypt access with logging and next-business-day review. Preserve CD-ENC-001 destruction approvals and CD-BDR-001 clean recovery, tenant integrity and dependency gates. Backup frequency, retention, RTO and RPO remain TBD pending BIA/business and contractual review. This change policy sets no numerical recovery objective or universal backup retention.

Vendor and privacy changes

Assess new or changed integrations, OAuth scopes, data flows, subprocessors, regions, exports and deletion behavior before enabling access to scoped information. The Engineering Lead reviews the vendor assessment. The CTO accepts material residual risk. Reassess critical vendors annually and after material changes or incidents. Record shared dependencies and exit/recovery limitations. Coordinate external communications through the CTO with appropriate advice under CD-IRP-001. There is no universal notification deadline. Provider assurance does not establish CloudDesk compliance.

Change Management Policy

6. Records, exceptions and review

Proposed audit trail and retention

Keep the ticket and classification, risk assessment, reviewed PR/commit and artifact identity. Keep CI/test outputs, approval decisions and timestamps, and deployment actor/actions. Keep production verification, rollback, incident linkage and closure records.

Restrict evidence access, preserve version history and minimize personal data. Record approved retention and holds before disposal. These are proposed records, not actual audit artifacts. Preserve minimum 12-month retention for KMS audit logs only. It is not a universal change-ticket, incident-evidence or backup retention rule.

Exceptions expire and require review

Before a planned deviation, the owner must record the requirement, scope, reason and security/privacy/tenant risk. Include compensating safeguards, remediation owner and expiry. The Engineering Lead assesses the request. The CTO approves or rejects it. Exceptions expire within 90 days and are reviewed monthly. Renewal requires fresh assessment and approval. Expired approval cannot authorize a planned deployment. Emergency deviations require a linked incident and CTO review by the next business day. Domain-specific access, encryption and destructive key authority remains in force. No active exception is asserted.

Periodic process and failed-change review

The Engineering Lead reviews change records and the proposed standard catalogue at least quarterly and after significant failed changes or incidents. Check unauthorized changes, repeated emergencies, stale preauthorizations, approval conflicts, rollback outcomes and overdue corrective actions. Suspend unsafe standard procedures, assign remediation and retest before reuse. Add material risks to the risk register. Retain quarterly open-risk reviews and CTO risk acceptance. Assess security risk at least annually and before material changes. These proposed review activities are not claimed completed.

Annual policy review and human adoption gate

The Engineering Lead reviews this policy annually and after material changes, significant incidents or lessons learned, and submits revisions to the CTO. Human reviewers must validate staffing/substitutes, approval thresholds and feasible separation of duties. They must check actual CI and deployment controls, tenant tests, freeze rules, vendor dependencies and recovery readiness against all five related policies. Record reviewer feedback and CTO approval before operational adoption. Approval_status: not_recorded; review_status: requires_user_review. This proposed policy does not provide evidence that CloudDesk has implemented or tested these controls.